



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



AI brands as bait: How threat actors are using the AI hype in social engineering

Threat Actor Profile

Classification	TLP:CLEAR
Published	2026-06-16
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Actor Profile

TLP:CLEAR | Lost Boys Cyber | AI brands as bait: How threat actors are using the AI hype in social engineering - Threat Actor Profile

Published: 2026-06-16 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

AI Brands as Bait: How Threat Actors Are Using the AI Hype in Social Engineering

Field	Value
Classification	TLP:CLEAR
Report ID	LBC-TAP-2026-009
Report Family	Threat Actor Profile
Source	Microsoft Security Blog / Microsoft Threat Intelligence
Source Published	2026-06-08
Prepared For	Lost Boys Cyber defensive research and detection engineering
Analyst Confidence	High for Microsoft-observed campaign details; Moderate for extrapolated enterprise exposure patterns and hunt logic
Scope	AI-brand impersonation campaigns using phishing, malvertising, SEO abuse, GitHub release abuse, signed malware, and Vidar/Lumma/Hijack Loader/Oyster delivery

1. Executive Summary

Microsoft Threat Intelligence reported a set of 2026 social-engineering campaigns that abuse public interest in high-profile AI brands including ChatGPT, Anthropic Claude, DeepSeek, Microsoft Copilot-adjacent themes, and AI video/plugin language. Lost Boys Cyber assesses this activity as a durable lure class rather than a short-lived trend: threat actors are not compromising the referenced AI vendors, but they are exploiting brand trust, user curiosity, search intent, and urgency-driven account narratives to increase click-through, credential theft, payment-card theft, and malware execution.

The campaigns span several tradecraft patterns. A ChatGPT-themed payment lure redirected users through legitimate and abused redirector infrastructure before collecting personal and credit-card data. A Claude-themed campaign used PDF attachments, CAPTCHA-style gating, and likely adversary-in-the-middle (AiTM) sign-in flows to collect credentials and access tokens across more than 2,000 organizations. Storm-3075, assessed by Microsoft as an initial access broker and malware distributor, used AI-themed malvertising to deliver signed malware and ultimately Vidar Stealer, with overlap to Lumma Stealer, Hijack Loader, and Oyster distribution. A separate DeepSeek V4 GitHub impersonation campaign used SEO, release assets, stolen branding, and rotating archives to deliver Vidar through fake installer packages.

The defensive implication is clear: organizations should treat AI-brand lures as a cross-surface initial-access problem touching email, identity, browser, endpoint, software supply-chain trust cues, and user search behavior. Priority controls are phishing-resistant MFA, Safe Links/time-of-click URL inspection, URL and attachment detonation, endpoint controls for signed-but-suspicious binaries, software allowlisting, GitHub/release-asset download monitoring, and focused hunts for AI-themed executable names, archive names, redirect chains, Python droppers in user profile paths, and Vidar-family network activity.

Priority Finding	Defensive Impact	Confidence
AI-brand abuse is being operationalized across phishing, malvertising, and SEO-driven malware delivery rather than a single campaign family.	Detection must correlate email, web, identity, endpoint, and developer-platform telemetry.	High

Storm-3075 used AI-themed malvertising to distribute signed malware and Vidar Stealer at large scale.	Code-signing trust is insufficient by itself; signed binaries from user-writable paths require behavioral scrutiny.	High
Fake AI tool repositories and release assets can rank highly in GitHub/search results and imitate legitimate software launch behavior.	Security teams should monitor brand/AI-tool download intent and restrict unmanaged installer execution.	High
CAPTCHA-like gates and required user interaction were used in both phishing and malware chains to impede automated analysis.	Sandbox-only verdicting can miss gated stages; human-click and interactive detonation workflows remain important.	Moderate-High
Microsoft observed overlap with Fox Tempest malware-signing-as-a-service and Vidar/Lumma/Hijack Loader/Oyster delivery ecosystems.	Campaign response should include infostealer containment, token reset, browser credential review, and downstream intrusion checks.	High

2. Intelligence Requirement

This report answers the following Lost Boys Cyber intelligence requirement:

Requirement	Answered By
What AI-themed lures are currently being used for credential theft, payment-card theft, and malware delivery?	Microsoft-observed ChatGPT, Claude, “Awesome AI Windows Plugin,” “Flux Pro AI,” and DeepSeek V4 campaigns.
Which actors or ecosystems are linked to the activity?	Storm-3075 initial access broker/distributor activity; Fox Tempest malware-signing-as-a-service; downstream Vidar/Lumma/Hijack Loader/Oyster payload ecosystems.
What enterprise telemetry should be prioritized for detection?	Email URL clicks, Safe Links verdicts, PDF attachment handling, GitHub release downloads, archive extraction, signed executable execution from user profile paths, Python droppers, and Vidar C2 communications.
What should defenders do immediately?	Enforce phishing-resistant MFA, strengthen time-of-click URL inspection, restrict untrusted installers, monitor AI-themed software downloads, and hunt for provided IOCs and behaviors.

Key assumptions used in this report:

- Microsoft’s public reporting is treated as the primary source of truth for observed activity, dates, IOCs, and attribution labels.
- Microsoft Defender detection names are included as source context; Lost Boys Cyber detection logic is written generically for M365 Defender, SIEM, and EDR environments and should be tuned before production blocking.
- Some referenced domains/repositories were taken down before this report; historical telemetry, proxy logs, EDR data, and email security logs are therefore the expected validation sources.

3. Source Review and Confidence

Source	Relevance	Reliability	Notes
--------	-----------	-------------	-------

Microsoft Security Blog, “AI brands as bait: How threat actors are using the AI hype in social engineering,” 2026-06-08	Primary campaign reporting, telemetry statistics, IOCs, Microsoft Defender detection coverage	High	Direct reporting from Microsoft Threat Intelligence and Microsoft Defender telemetry.
Microsoft-linked actor names Storm-3075 and Fox Tempest	Attribution and ecosystem context	Moderate-High	Actor labels are vendor-specific but operationally useful for clustering initial-access and signing-service behavior.
Microsoft-provided IOCs	Detection and retrospective hunting	High for reported artifacts; time-bound for active infrastructure	Several URLs/repositories were taken down; use for historical matching and enrichment.
Public references cited by Microsoft to Trend Micro, Zscaler ThreatLabz, and Huntress	Context for the broader fake-AI/fake-tool ecosystem	Moderate	Useful corroboration for sibling lure families, but not independently revalidated in this task.

Analyst confidence is High that the reported campaigns occurred as described because Microsoft provided campaign timelines, victim telemetry, observed IOCs, and product detection coverage. Confidence is Moderate-High that the same lure class will persist because it aligns with repeated attacker behavior: abuse of trusted brands, urgent account narratives, SEO manipulation, signed malware, and user-driven execution.

Evidence limitations:

- This review did not include direct malware reverse engineering or sandbox execution of the listed Vidar samples.
- The final Claude redirect destination was inactive at Microsoft’s analysis time; AiTM assessment is based on infrastructure overlap, intermediate logic, and source-code indicators.
- Search result rankings for fake repositories are volatile; Microsoft’s observed rankings should be treated as a point-in-time exposure measurement.

4. Key Findings

Finding	Evidence	Defensive Meaning
AI platform brands are now a repeatable lure class.	Microsoft observed campaigns impersonating ChatGPT, Claude, DeepSeek, Copilot-adjacent AI interest, “Awesome AI Windows Plugin,” and “Flux Pro AI.”	Awareness training and detection content should explicitly include AI-tool payment, policy, installer, plugin, and model-download themes.
Phishing campaigns use trusted-service redirect chains.	ChatGPT-themed emails redirected through Bitrix24, AWS tracking, Rebrandly, and a compromised-looking landing domain before collecting PII and card data.	URL filtering must evaluate redirect chains at time of click, not only the first visible link.
Claude-themed phishing targeted enterprise identities at scale.	Microsoft observed emails to more than 2,000 organizations, concentrated in the United States, United Kingdom, and India, especially IT, business, and financial services.	Identity telemetry and token-theft defenses are central; PDF attachment workflows require scrutiny.
Storm-3075 used AI-themed malvertising for malware delivery.	Microsoft observed a March 13, 2026 run targeting more than 66,000 devices and delivering a signed executable hosted on GitHub.	Treat malvertising and unmanaged downloads as initial-access channels even when the binary is signed.

Fraudulently obtained signing certificates increased trust.	The “Awesome AI Windows Plugin” executable was signed with certificate thumbprint 4f5c5b3ef45cfff7721754487a86aeff9a2e6e32, linked by Microsoft to Fox Tempest MSaaS.	Signing status should be one signal, not an allow decision; reputation, path, parent process, and behavior matter.
Fake GitHub releases abused AI launch interest and search intent.	DeepSeek-V4/deepseek-V4 used stolen branding, real benchmark data, SEO tags, llms.txt, releases, stars/forks, and rotating archives.	Developer and analyst endpoints need controls around GitHub release downloads, archive extraction, and unsigned/untrusted model installers.
User-interaction gates reduce sandbox visibility.	Phishing pages used CAPTCHA-style prompts; the malware required a “Continue” checkbox before malicious behavior began.	Automated detonation should include interactive workflows; lack of immediate behavior is not a clean verdict.

5. Threat Context

The activity sits at the intersection of three attacker advantages: user curiosity around AI, trusted platform abuse, and mature commodity malware distribution. The lures are timely and believable because users increasingly expect to interact with AI subscriptions, model releases, productivity assistants, plugins, and downloadable tooling. Threat actors then map those expectations onto old but effective mechanics: payment update prompts, account enforcement notices, fake installers, SEO-optimized repositories, redirectors, and signed binaries.

Campaign / Lure	Delivery Surface	User Action Required	Objective	Notable Tradecraft
ChatGPT Plus payment update	Email phishing	Click payment-update button, complete CAPTCHA-like prompt, enter PII and payment card	Financial fraud and personal data theft	Display-name impersonation, urgency, legitimate redirector chain, staged form collection
Claude appeal / account policy violation	Email plus PDF attachment	Open PDF, copy appeal code, click link, complete Cloudflare-style gate	Credential and token theft, likely AiTM	Enforcement-themed lure, PDF instructions, mobile/desktop conditional redirects, CAPTCHA gating
“Awesome AI Windows Plugin” / “Flux Pro AI”	Malvertising from streaming/popup ecosystem	Download and execute installer, click in-app “Continue”	Vidar Stealer delivery; broader malware distribution	GitHub-hosted executable, fraudulent code signing, Python downloader, shellcode loader, C2 retrieval
Fake DeepSeek V4 GitHub releases	GitHub/search/AI-assisted search discovery	Download 7z archive, extract executable, run installer	Vidar Stealer and potentially additional malware	Stolen branding, real benchmark data, SEO topics, llms.txt, release-asset CDN abuse, rotating archive hashes

Microsoft tied the malvertising distribution behavior to Storm-3075, described as an initial access broker and malware distributor delivering final payloads for multiple downstream actors. The use of Fox Tempest-linked code-signing services illustrates how commodity distribution ecosystems can purchase trust signals at scale. For defenders, the key lesson is not that every AI-branded download is suspicious; it is that AI launch cycles now create short windows where fake repositories, fake installers, and fake policy notices can appear credible before official documentation and search rankings stabilize.

5.1 MITRE ATT&CK Mapping

Tactic	Technique	Observed / Assessed Behavior	Confidence
Reconnaissance / Resource Development	T1583.006 Web Services; T1585 Accounts	Fake GitHub organization/repository, release tags, SEO topics, and llms.txt used for DeepSeek lure.	High
Resource Development	T1588.003 Code Signing Certificates	Fraudulently obtained Microsoft-issued code-signing certificate used to sign malware.	High
Initial Access	T1566.002 Spearphishing Link	ChatGPT payment lure delivered malicious URLs through redirect chains.	High
Initial Access	T1566.001 Spearphishing Attachment	Claude campaign used PDF attachment with embedded link and appeal workflow.	High
Initial Access	T1189 Drive-by Compromise	Malvertising from streaming/popup ecosystem redirected users to malware download pages.	Moderate-High
Execution	T1204.002 User Execution: Malicious File	Users manually launched ProFluxeFlowAi-win-Setup.exe or fake DeepSeek installer executables.	High
Defense Evasion	T1027 Obfuscated/Compressed Files and Information	DeepSeek payloads delivered inside .7z archives with rotating hashes.	Moderate
Defense Evasion	T1497 Virtualization/Sandbox Evasion	CAPTCHA-style web gates and executable "Continue" checkbox impeded automated analysis.	Moderate
Defense Evasion	T1553.002 Code Signing	Signed malware increased apparent trust and may reduce early detection.	High
Credential Access	T1556.002 AiTM; T1539 Steal Web Session Cookie	Claude campaign likely led to Microsoft sign-in phishing and access-token interception.	Moderate-High
Credential Access	T1056 / T1555 family	Vidar Stealer can collect credentials, browser data, and other user secrets.	High for payload family behavior; source did not enumerate full config.
Command and Control	T1105 Ingress Tool Transfer	Python downloader retrieved next-stage payload from attacker C2.	High

5.2 Indicators of Compromise

Indicator	Type	Description	First Seen	Last Seen
791efb555eefb7215e96659a1353a97416743b66bdd72705493129c64057d40e	SHA-256	Claude-themed PDF attachment `Fill and Sign Claude Appeal Form.pdf`	2026-04-20	2026-04-20
hxxp://dash.awaydouble[.]org/0v2auth	URL	URL inside Claude-themed PDF attachment	2026-04-20	2026-04-20
hxxps://github[.]com/shippingtechnologymovie/AI-techVideos/releases/download/13123/ProFluxeFlowAi-win-Setup.exe	URL	Fraudulent GitHub repository hosting malware executable	2026-03-13	2026-03-14
c7c5072df9f83f4c440a5c3bb4be1d5f6c67bbf78f196406ca20d27b43b975b8	SHA-256	`ProFluxeFlowAi-win-Setup.exe`	2026-03-13	2026-03-14
4f5c5b3ef45cfff7721754487a86aef9a2e6e32	Signer SHA-1	Fraudulent code-signing certificate thumbprint	2026-03-13	2026-03-14
brokeapt[.]com	Domain	Attacker-controlled C2 domain for Python loader	2026-03-10	2026-05-20
pan.ssffaa19[.]xyz	Domain	Vidar C2	2026-03-13	2026-03-14
pan.rongtv[.]xyz	Domain	Vidar C2	2026-03-13	2026-03-14
hxxps://github[.]com/DeepSeek-V4/deepseek-V4/releases/download/deepseek-V4/deepseek-v4-pro_x64.7z	URL	Fraudulent DeepSeek V4 GitHub release asset	2026-04-24	2026-04-28
0a26238f6c516de5885457c93042531aa59bc206a9537cebf5267cedc6c68531	SHA-256	`deepseek-v4-pro_x64.7z` v1	2026-04-24	2026-05-18
8610d4fb0ec5b525071c2aaec4df0f8fcb3673aba58a7e1959fc44e83c0e2ca	SHA-256	`deepseek-v4-flash_x64.7z` v1	2026-04-24	2026-04-28
99231deb373997364381d1eb513d2d42231d418c3a2db9007c5af9bd56ab9371	SHA-256	`deepseek-v4-flash_x64.7z` v2	2026-04-26	2026-04-28
25270cc429ada8028b5b33220ed412c47907ecce	SHA-256	`deepseek-v4-	2026-04-26	2026-04-28

ea7377d608fac5af01bed56a		pro_x64.7z` v2		
56d722b0331bf0aaa86bb37483486c6dff6ad9427fc473ed7c3226c21a9bdd23	SHA-256	DeepSeek-specific extracted PE (`deepseek-v4-pro_x64.exe`, `deepseek-v4-flash_x64.exe`, `VectorEngine.exe`)	2026-04-26	2026-04-28
5455341ed1bbe75a664fca2dd0794c508e1874f75360253a7ff5bc119bc92d80	SHA-256	Shared loader observed under multiple AI-brand lure names	2026-04-12	2026-05-21

6. Detection and Hunting

Detection should combine high-confidence IOC matching with behavior-led analytics. The IOCs are useful for retrospective scoping, but the more durable detection layer is the pattern: AI-themed lures, trusted redirectors, PDF-to-login workflows, GitHub release downloads, archive extraction, signed executables in user-writable paths, Python droppers in AppData, and outbound traffic to suspicious C2 shortly after installer execution.

Detection Area	Data Source	Detection Idea	Priority
AI-themed phishing	Email security, M365 Defender, SEG logs	Sender display names/subjects using ChatGPT, Claude, Anthropic, AI payment/update/appeal terms plus URL-click telemetry.	High
PDF-to-phish workflow	Email attachment logs, endpoint file events, proxy logs	PDF attachment opened followed by connection to newly registered or suspicious domains and identity sign-in pages.	High
Redirector abuse	Proxy, DNS, Safe Links, browser telemetry	Multi-hop chains involving legitimate redirectors and final landing pages with AI-brand paths such as `/ChatGPT/`.	Medium-High
GitHub release malware	Proxy, EDR, download logs	Download from GitHub release assets followed by archive extraction and execution from Downloads or user profile paths.	High
Signed malware behavior	EDR process/file/certificate telemetry	Signed executable with low reputation, AI-themed name, user-writable path, unusual parent, and post-execution Python/dropper behavior.	High
Vidar-family C2	DNS, proxy, EDR network telemetry	Connections to known domains or newly observed suspicious hosts shortly after fake AI installer execution.	High

Token theft / AiTM	Entra ID, identity provider logs	Unfamiliar sign-in properties, anomalous token alerts, impossible travel, session-cookie indicators following Claude-themed phish.	High
--------------------	----------------------------------	--	------

6.1 Microsoft 365 Defender / Advanced Hunting Queries

AI-themed email lure and click triage:

```
let AiTerms = dynamic(["chatgpt", "claude", "anthropic", "deepseek", "copilot", "gpt-5", "flux pro ai", "awesome ai", "ai windows plugin"]);
EmailEvents
| where Timestamp > ago(30d)
| where Subject has_any (AiTerms) or SenderDisplayName has_any (AiTerms)
| project Timestamp, NetworkMessageId, SenderFromAddress, SenderDisplayName, RecipientEmailAddress, Subject, DeliveryAction, ThreatTypes, DetectionMethods
| join kind=leftouter (
    UrlClickEvents
    | where Timestamp > ago(30d)
    | project ClickTime=Timestamp, NetworkMessageId, AccountUpn, Url, ActionType, IsClickedThrough
) on NetworkMessageId
| order by Timestamp desc
```

PDF attachment followed by suspicious web activity:

```
let SuspiciousPdfNames = dynamic(["Fill and Sign Claude Appeal Form.pdf", "Claude Appeal", "Appeal Form"]);
EmailAttachmentInfo
| where Timestamp > ago(30d)
| where FileName has_any (SuspiciousPdfNames) or (FileType =~ "pdf" and FileName has_any (dynamic(["Claude", "Anthropic", "Appeal", "AUP"])))
| project Timestamp, NetworkMessageId, RecipientEmailAddress, FileName, SHA256
| join kind=leftouter (
    UrlClickEvents
    | where Timestamp > ago(30d)
    | project ClickTime=Timestamp, NetworkMessageId, AccountUpn, Url, ActionType, IsClickedThrough
) on NetworkMessageId
| order by Timestamp desc
```

GitHub release archive or executable download followed by execution:

```
let AiFileTerms = dynamic(["deepseek", "gpt", "claude", "kimi", "seedance", "gemma", "grok", "manus", "fraudgpt", "flux", "awesome-ai", "ai-tech"]);
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has_any (AiFileTerms) or FileName has_any (AiFileTerms)
| where FileName endswith ".exe" or FileName endswith ".7z" or FileName endswith ".zip" or FileName endswith ".rar"
| project FileTime=Timestamp, DeviceName, InitiatingProcessAccountUpn, FileName, FolderPath, SHA256, InitiatingProcessFileName, InitiatingProcessCommandLine
| join kind=leftouter (
    DeviceProcessEvents
    | where Timestamp > ago(30d)
    | where FileName has_any (AiFileTerms) or ProcessCommandLine has_any (AiFileTerms)
    | project ExecTime=Timestamp, DeviceName, AccountUpn, FileName, ProcessCommandLine, SHA256, InitiatingProcessFileName, InitiatingProcessCommandLine
) on DeviceName, SHA256
| order by FileTime desc
```

Python downloader staged from AppData after suspicious installer launch:

```
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ ("pythonw.exe", "python.exe")
| where FolderPath has_any (dynamic(["\\AppData\\Local\\", "\\Users\\"]))
| where InitiatingProcessFolderPath has_any (dynamic(["\\Downloads\\", "\\AppData\\Local\\", "\\Temp\\"])
```

```
\"])))
| project Timestamp, DeviceName, AccountUpn, FileName, FolderPath, ProcessCommandLine,
InitiatingProcessFileName, InitiatingProcessFolderPath, InitiatingProcessCommandLine,
InitiatingProcessSHA256
| order by Timestamp desc
```

Known IOC matching across endpoint and network telemetry:

```
let Hashes = dynamic([
"791efb555eefb7215e96659a1353a97416743b66bdd72705493129c64057d40e",
"c7c5072df9f83f4c440a5c3bb4be1d5f6c67bbf78f196406ca20d27b43b975b8",
"0a26238f6c516de5885457c93042531aa59bc206a9537cebf5267cedc6c68531",
"8610d4fb0ec5b525071c2aaec4df0f8fcb3673aba58a7e1959fc44e83c0e2ca",
"99231deb373997364381d1eb513d2d42231d418c3a2db9007c5af9bd56ab9371",
"25270cc429ada8028b5b33220ed412c47907ecceea7377d608fac5af01bed56a",
"56d722b0331bf0aaa86bb37483486c6dff6ad9427fc473ed7c3226c21a9bdd23",
"5455341ed1bbe75a664fca2dd0794c508e1874f75360253a7ff5bc119bc92d80"]);
let Domains = dynamic(["brokeapt.com", "pan.ssffaa19.xyz", "pan.rongtv.xyz", "dash.awaydouble.org"]);
union isfuzzy=true
(DeviceFileEvents | where SHA256 in~ (Hashes) | project Timestamp, DeviceName,
Account=InitiatingProcessAccountUpn, Indicator=SHA256, Source="file", FileName, FolderPath),
(DeviceProcessEvents | where SHA256 in~ (Hashes) | project Timestamp, DeviceName, Account=AccountUpn,
Indicator=SHA256, Source="process", FileName, FolderPath),
(DeviceNetworkEvents | where RemoteUrl has_any (Domains) | project Timestamp, DeviceName,
Account=InitiatingProcessAccountUpn, Indicator=RemoteUrl, Source="network",
FileName=InitiatingProcessFileName, FolderPath=InitiatingProcessFolderPath)
| order by Timestamp desc
```

Identity follow-up after suspected Claude/AiTM lure:

```
let SuspectUsers = UrlClickEvents
| where Timestamp > ago(30d)
| where Url has_any (dynamic(["awaydouble", "pureplantcravings", "Claude", "Anthropic", "appeal"]))
| distinct AccountUpn;
IdentityLogonEvents
| where Timestamp > ago(30d)
| where AccountUpn in (SuspectUsers)
| where ActionType has_any (dynamic(["LogonSuccess", "LogonFailed"]))
| project Timestamp, AccountUpn, IPAddress, Location, DeviceName, Application, ActionType, LogonType,
FailureReason, RiskLevel, AdditionalFields
| order by Timestamp desc
```

6.2 Sigma Detection: Suspicious AI-Branded Installer Execution

```
title: Suspicious AI-Branded Installer Executed From User-Writable Path
id: 2e93d8c7-7c52-4a46-ae2a-ai-brand-lure-001
status: experimental
description: Detects execution of AI-themed installer names from Downloads, AppData, or Temp paths,
consistent with fake AI-tool malware lures reported by Microsoft.
author: Lost Boys Cyber
date: 2026-06-16
references:
- https://www.microsoft.com/en-us/security/blog/2026/06/08/ai-brands-as-bait-how-threat-actors-are-
using-the-ai-hype-in-social-engineering/
logsource:
  category: process_creation
  product: windows
detection:
  selection_path:
    Image|contains:
      - '\\Users\\'
      - '\\Downloads\\'
      - '\\AppData\\Local\\'
      - '\\AppData\\Roaming\\'
      - '\\Temp\\'
  selection_name:
    Image|contains:
      - 'deepseek'
```

```

- 'gpt'
- 'claude'
- 'kimi'
- 'seedance'
- 'gemma'
- 'grok'
- 'manus'
- 'fraudgpt'
- 'flux'
- 'awesome'
- 'ai'
Image|endswith: '.exe'
condition: selection_path and selection_name
fields:
- UtcTime
- Image
- CommandLine
- ParentImage
- User
falsepositives:
- Legitimate AI tooling installed by developers or analysts from user profile paths. Tune with approved publisher, hash, and software inventory allowlists.
level: medium

```

6.3 SPL Hunt: GitHub Release Download Followed by Archive Extraction or Execution

```

(index=proxy OR index=edr) earliest=-30d
((url="*github.com/*/releases/download/*" OR url="*objects.githubusercontent.com*" OR url="*github-releases.githubusercontent.com*")
AND (url="*.7z*" OR url="*.zip*" OR url="*.exe*" OR url="*.rar*"))
| eval ai_lure=if(match(lower(url), "deepseek|chatgpt|gpt|claude|anthropic|kimi|seedance|gemma|grok|manus|fraudgpt|flux|awesome.*ai"), 1, 0)
| where ai_lure=1
| table _time src user url http_user_agent action bytes_out bytes_in
| sort - _time

```

6.4 Practical Hunt Questions

Hunt Hypothesis	Query Focus	Triage Steps
A user clicked an AI-branded payment or account-enforcement phish.	Email subject/display name plus URL clicks to redirectors or newly observed domains.	Review message headers, URL chain, clicked-through status, landing page screenshots, and any subsequent credential prompts.
A user downloaded a fake AI installer from GitHub.	GitHub release downloads with AI-themed file names, followed by extraction and executable launch.	Collect file hash, publisher certificate, process tree, parent browser, download URL, and network beacons.
Signed malware bypassed user suspicion.	Signed binaries from Downloads/AppData with low prevalence and suspicious post-execution behavior.	Validate signer thumbprint, certificate chain, revocation status, reputation, and child process activity.
Vidar or another stealer executed.	Known hash/domain matches, Python downloader behavior, browser credential access, archive staging.	Isolate host, preserve memory/disk artifacts, rotate passwords/tokens, review browser credential stores and session cookies.
Claude-themed AiTM compromised a cloud account.	Suspicious sign-ins after Claude/Anthropic lure interaction.	Revoke sessions, reset credentials, invalidate refresh tokens, review inbox rules/OAuth grants, and inspect impossible travel/unfamiliar properties.

7. Recommendations

Priority	Recommendation	Owner	Target Outcome
P1	Enforce phishing-resistant MFA for privileged users and high-risk applications; remove MFA exclusions.	Identity / IAM	Reduce credential and token theft impact from AiTM phishing.
P1	Enable Safe Links or equivalent time-of-click URL rewriting and scanning for email, Teams/chat, and Office documents.	Email Security	Detect redirect chains and malicious final destinations after delivery.
P1	Block or require approval for untrusted executables and archives downloaded from user browsers, especially from GitHub release assets and user-writable paths.	Endpoint / IT	Prevent fake AI installer execution.
P1	Hunt for Microsoft-provided IOCs and the behavior-led patterns in Section 6 across the last 30-90 days.	SOC / Threat Hunting	Scope historical exposure and identify compromised users or endpoints.
P2	Treat signed binaries with suspicious provenance as investigatory leads, not trusted software.	Detection Engineering	Catch fraudulently signed malware and MSaaS-enabled campaigns.
P2	Add AI-brand abuse scenarios to user-awareness training: fake subscription payment updates, account-policy appeals, model downloads, plugins, and GitHub installers.	Security Awareness	Reduce click-through and execution rates for AI-themed lures.
P2	Monitor for newly observed AI-themed domains, GitHub organizations, repositories, release assets, and llms.txt files that mimic popular AI products.	CTI / Brand Protection	Detect search- and LLM-discoverable lure infrastructure early.
P2	Ensure sandbox workflows support interactive gates and delayed behavior.	Malware Analysis / SOC Engineering	Avoid false negatives from CAPTCHA-like or click-to-continue malware stages.
P3	Baseline legitimate AI tooling in the environment and publish an approved-source list.	IT / Security Architecture	Make fake installer detection easier and reduce user reliance on search results.

Incident response guidance for confirmed hits:

- For phishing/payment-card collection: preserve email and URL evidence, identify clicked users, remove delivered messages, block domains/URLs, notify affected users, and follow payment-card incident procedures if card data was entered.

- For suspected AiTM credential theft: revoke sessions and refresh tokens, reset credentials, review OAuth grants and inbox rules, inspect sign-in risk, and monitor for lateral movement or business-email-compromise behavior.
- For Vidar or related stealer execution: isolate the endpoint, collect volatile evidence where feasible, remove persistence, rotate credentials stored on the host, invalidate browser sessions, and investigate downstream access from stolen credentials.
- For fake GitHub installer exposure: identify all downloads of related release assets, check archive extraction events, verify whether executables ran, and block sibling lure names listed in Microsoft's reporting.

8. References

- [1] Microsoft Security Blog / Microsoft Threat Intelligence, "AI brands as bait: How threat actors are using the AI hype in social engineering," published 2026-06-08. <https://www.microsoft.com/en-us/security/blog/2026/06/08/ai-brands-as-bait-how-threat-actors-are-using-the-ai-hype-in-social-engineering/>
- [2] Microsoft Threat Intelligence, Microsoft Defender detections and mitigation guidance cited in the source article, including Defender for Office 365, Defender for Endpoint, Defender Antivirus, Entra ID Protection, and Defender for Cloud Apps coverage.
- [3] Microsoft reporting references to Storm-3075 initial access broker/malware distributor activity and Fox Tempest malware-signing-as-a-service activity, as summarized in the source article.
- [4] Public ecosystem reporting referenced by Microsoft from Trend Micro, Zscaler ThreatLabz, and Huntress on related fake-AI/fake-tool lure families and Vidar/GhostSocks delivery patterns.